AUDIT REPORT · AUD-2026-IAM-01

Strong authentication and privileged access — KRL-ADM

Banque Kerlann (fictive) · KRL-ADM — console d'administration IAM

Lead auditor: **A. Auditeur** Owner: **DSI — équipe IAM** Date: **2026-11-02 23:21**

Run: **08-kerlann-apres-correctifs**

1. Executive summary

OPINION AT TESTING

Needs improvement

7 controls tested	**1** findings	**0** findings closed and verified	**1** open findings
0 human approvals	**8** personal data items masked in evidence	**0 min 18 s** audit duration	**$0.649 *** measured AI cost

Critical: 0 High: 1 Medium: 0 Low: 0

Key messages

- 1 finding across 7 controls: 1 high.
- 1 finding remains open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-2026-IAM-01
Entity	Banque Kerlann (fictive)
System	KRL-ADM — console d'administration IAM
System criticality	Supporte des fonctions critiques ou importantes (DORA)
Environment	Pré-production de démonstration
Owner	DSI — équipe IAM
Lead auditor	A. Auditeur
Date	2026-11-02 23:21
Framework	DORA art. 9(4) · RTS (UE) 2024/1774 art. 12, 21 · PSI-4
Work programme	existing catalogue reused · controls/AUD-2026-IAM-01.en.json

In scope

- Paramètres d'authentification et de session de la console KRL-ADM
- Comptes disposant d'un accès à la console
- Journalisation des actions d'administration

Out of scope

- Efficacité intrinsèque des facteurs MFA (robustesse des moyens d'authentification)
- Annuaire central et fédération d'identité
- Contrôles physiques

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	AFTER	STATUS	DUE DATE
F-01	PSI-4.7	No generic or shared admin accounts	High	Non-compliant		Open	2027-01-31
—	PSI-4.1	Mandatory MFA for privileged accounts	Critical	Compliant			
—	PSI-4.2	Mandatory MFA for users of critical system	High	Compliant			
—	PSI-4.3	Strong password policy	Medium	Compliant			
—	PSI-4.4	Account lockout after failed logins	Medium	Compliant			
—	PSI-4.5	Inactive session timeout	Medium	Compliant			
—	PSI-4.6	Logging of administration actions	High	Compliant			

4. Detailed findings and controls

F-01 PSI-4.7 No generic or shared admin accounts — High — Non-compliant — Open

CRITERIA

No account with role admin is generic or shared and every admin has a nominative login of the form initiale.nom with a personal email

PSI-4.7 · DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)

CONDITION

Observed: `[{"login": "a.lefloch", "email": "a•••@kerlann-banque.example", "role": "admin"}, {"login": "ops", "email": "o•••@kerlann-banque.example", "role": "admin"}]`

Expected: `for all users where role == admin: login matches initiale.nom pattern and email is personal, with no function login and no shared mailbox`

1 of 2 admin account(s) violate nominative login or personal email requirements.

RISK

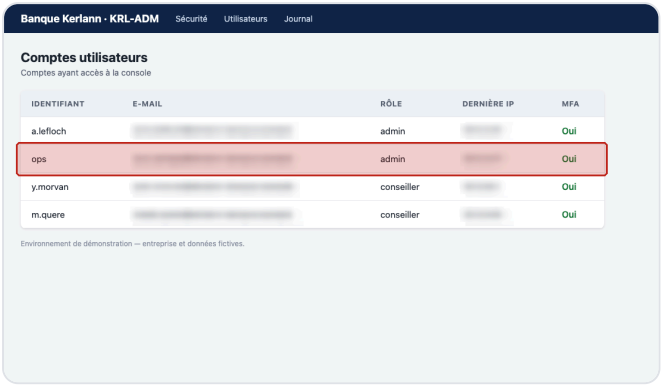
Generic or shared admin accounts destroy individual accountability and prevent attribution of privileged actions

RECOMMENDATION

Remove or disable generic and shared admin accounts and replace them with dedicated nominative accounts

Due date: 2027-01-31 · Owner: DSI — équipe IAM

Test procedure: Retrieve all accounts via GET /api/users and verify that every user with role admin has a nominative login and a personal email without function identifier or shared mailbox



At testing — The screenshot corroborates the test. The screenshot shows admin login ops with shared email o•••@kerlann-banque.example confirming the generic admin violation. · 8/8 personal data items masked

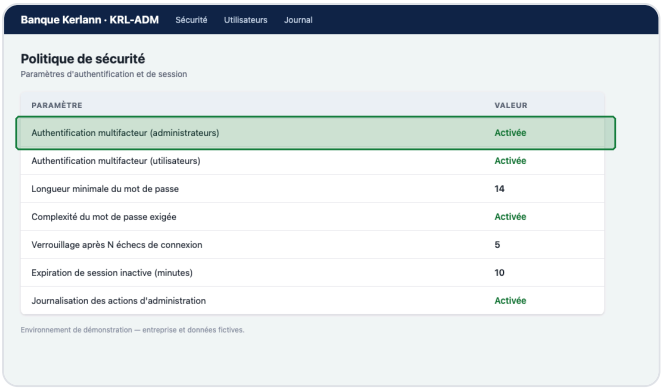
`2026-11-02 23:22:12 · SHA-256 7858ad57d1d24d7a…`

PSI-4.1 Mandatory MFA for privileged accounts

Critical · Compliant

Compliant control — MFA is enforced for all privileged admin accounts on KRL-ADM · DORA 9(4)(d), RTS 21(1)(f)(ii)

Observed: `true`

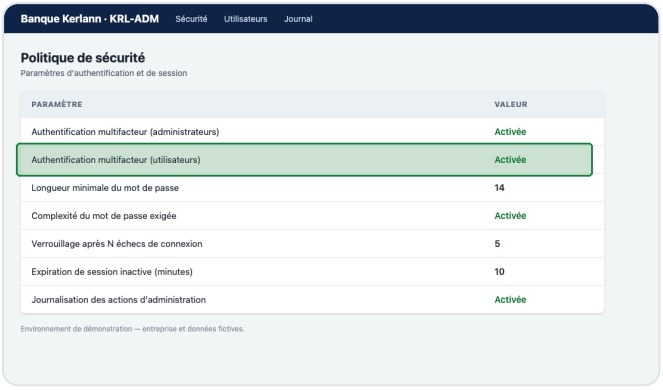


At testing — The screenshot corroborates the test. The security policy table shows administrator MFA as Activée, matching mfa_admin true.
2026-11-02 23:22:02 · SHA-256 1941516578a91581…

PSI-4.2 Mandatory MFA for users of critical system

High · Compliant

Compliant control — MFA is enforced for standard users because KRL-ADM supports critical or important functions · DORA 9(4)(d), RTS 21(1)(f)(ii)
Observed: `true`

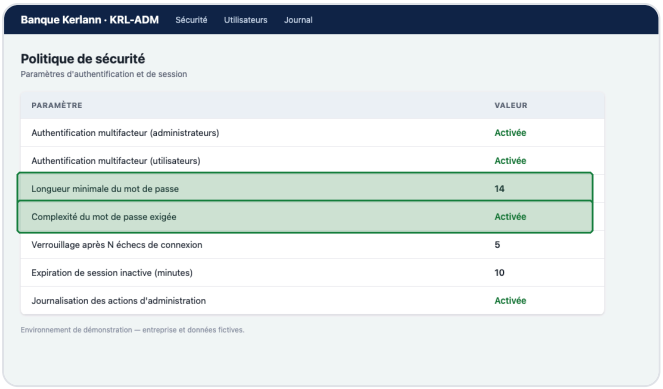


At testing — The screenshot corroborates the test. The screenshot shows MFA for standard users as Activee, matching the automated pass result.
2026-11-02 23:22:02 · SHA-256 3b0df5d1013eead7…

PSI-4.3 Strong password policy

Medium · Compliant

Compliant control — Passwords require a minimum length of 12 characters with complexity requirements enabled · DORA 9(4)(d)
Observed: `{"password_min_length": 14, "password_require_complexity": true}`



At testing — The screenshot corroborates the test. The screenshot shows minimum length 14 and complexity enabled, matching the automated result.

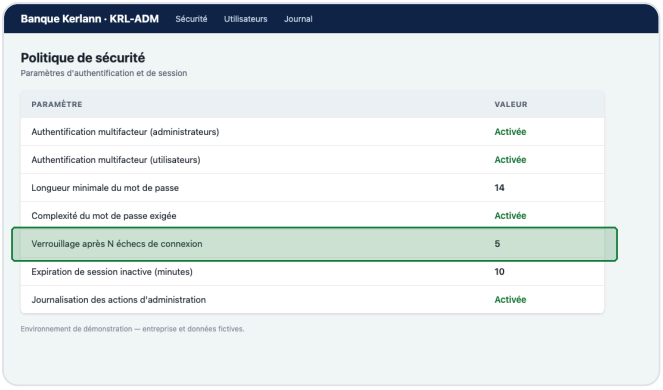
`2026-11-02 23:22:02 · SHA-256 72fde669176d8935…`

PSI-4.4 Account lockout after failed logins

Medium · Compliant

Compliant control — Accounts lock after at most 5 failed login attempts and lockout is never disabled · DORA 9(4)(c)

Observed: `5`



At testing — The screenshot corroborates the test. The screenshot shows the lockout threshold set to 5, matching the automated test observation.

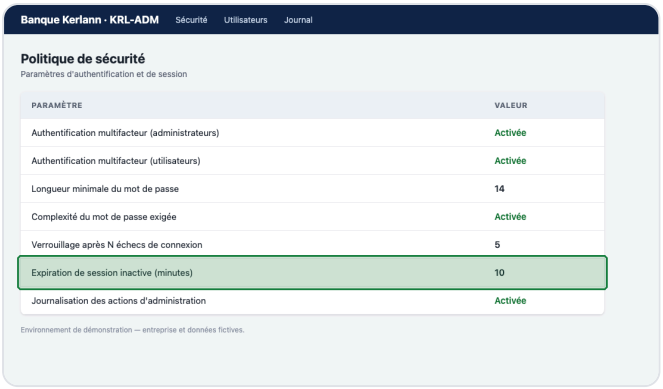
`2026-11-02 23:22:05 · SHA-256 045639c31be163f0…`

PSI-4.5 Inactive session timeout

Medium · Compliant

Compliant control — Inactive sessions expire after at most 15 minutes and expiration is never disabled · DORA 9(4)(c)

Observed: `10`



At testing — The screenshot corroborates the test. The screenshot shows inactive session expiration set to 10 minutes, which is within the required 1 to 15 range.

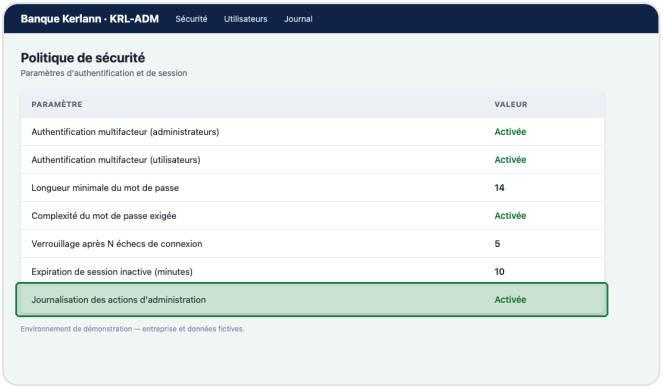
`2026-11-02 23:22:02 · SHA-256 12e128b157a33917…`

PSI-4.6 Logging of administration actions

High Compliant

Compliant control — All administration actions are logged · RTS 12(2)(c)(i)

Observed: `true`



At testing — The screenshot corroborates the test. The security policy table shows administration action logging as Activee, matching admin_audit_log true.

`2026-11-02 23:22:02 · SHA-256 bdf730e92c0c6f25…`

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.1	C1 · Mandatory MFA for privileged accounts	098d37cd0158dd1a · script library (reused)	Compliant
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.2	C2 · Mandatory MFA for users of critical system	fa35c17fbb1dfdd3 · script library (reused)	Compliant
DORA 9(4)(d)	PSI-4.3	C3 · Strong password policy	b440a5b4dc6b0fb3 · script library (reused)	Compliant
DORA 9(4)(c)	PSI-4.4	C4 · Account lockout after failed logins	10d2a8f06337b5bc · script library (reused)	Compliant
DORA 9(4)(c)	PSI-4.5	C5 · Inactive session timeout	4157e9750f010f98 · script library (reused)	Compliant
RTS 12(2)(c)(i)	PSI-4.6	C6 · Logging of administration actions	e2f3534909210977 · script library (reused)	Compliant
DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)	PSI-4.7	C7 · No generic or shared admin accounts	5e917770866b8e47 · script library (reused)	Non-compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-02 23:22:02	1941516578a91581ad5a36062585e806e0b3a782d99f0d5ebeb2119af0c472fc
evidence/C2_before.png	C2 · At testing	2026-11-02 23:22:02	3b0df5d1013eead746fb8f3469524b4b631ab5e9a7a2bfe22392281c53eaa510
evidence/C3_before.png	C3 · At testing	2026-11-02 23:22:02	72fde669176d8935288a3277c5dc75e28d7129728424d352b071c12d13ef075d
evidence/C4_before.png	C4 · At testing	2026-11-02 23:22:05	045639c31be163f0e0510215d26006c3c6d2262515b799495a5c2fa41d54e2a5
evidence/C5_before.png	C5 · At testing	2026-11-02 23:22:02	12e128b157a339178ee6ffd732e4cbd3b6464bac593ad4694e16a5a689956b0c
evidence/C6_before.png	C6 · At testing	2026-11-02 23:22:02	bdf730e92c0c6f2555eba9a699058dd9f1ef1c0c84dd0fd700ef56cc542fbc99
evidence/C7_before.png	C7 · At testing	2026-11-02 23:22:12	7858ad57d1d24d7ab0265fd6743bc40c1b6f6a6dd6105332e3dd29a53e232dce

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)

`muse-spark-1.3`	64	92,991	125,340	0	0.6489
`sam-3.1`	50	0	0	50	price not published
Total					**0.6489**

Personal data in evidence: 8/8 spotted by Muse Spark + SAM, 8/8 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`01b1a20eebc10e13b560f0ea88d29ebb0ba1d5e115a1496549e185c4e58be5fa`